unpruuf Security Audit Roadmap

NexonAI Consulting

Planning date 15 October 2026

Purpose and intended outcome

Commission an independent security assessment of a precisely identified version of the complete unpruuf solution. Separate assessments of the protocol and server, mobile app, and Compliance dashboard should be followed by an assessment of the complete message and reporting workflows. The outcome is a set of evidence-backed product statements, a traceable findings register, and an approved pilot release.

The product baseline is a separate system instance for each customer, running on the customer's own servers. NexonAI supplies the app and a small server program for a Windows PC, laptop, or server. Connections use Tor, and pairing allows contacts to be recognised. The node temporarily stores encrypted packages, with retention previously described as 1, 6, or at most 24 hours. Compliance provides a reporting channel with a reply path and separate case records held by the reporting office. These are properties to assess, not conclusions already established by an audit.

The working schedule allows twelve weeks to reach an assessed pilot release, followed by four weeks of pilot operation and evaluation. It is a sequencing assumption, not an effort estimate or delivery commitment. Auditor availability, code size, supported platforms, and architectural changes may extend the schedule. Week 1 starts when the scope is approved.

Roles and responsibilities

Role	Responsibility
Product Owner at NexonAI	Decide product statements, scope, priorities, budget, residual risks, and publication.
Security and architecture lead	Maintain data flows, the threat model, the key model, and assessment criteria.
Server and Windows development	Address the node, installation, Tor integration, resource limits, expiry, and operation.
Mobile development	Address supported mobile platforms, keys, pairing, and device storage.
Dashboard development	Address case access, local data, passwords, retention, and reporting workflows.
Independent auditor	Select and apply assessment methods, establish findings independently, and retest fixes.
Privacy and legal adviser	Assess the reporting process, legal basis, retention, and responsibilities separately from technical security.

Role	Responsibility
Pilot customer	Provide its own test environment and contacts, and document operation and usability.

One person may hold more than one internal role. Parallel work assumes sufficient internal capacity and available external assessors.

Delivery schedule

Phase	Weeks	Main work	Required outcome
1 Scope and evidence	1	Identify versions, platforms, claims, data flows, threats, and assessment proposals.	Versioned assessment brief and complete assessor access.
2 Internal preparation	2 to 3	Prepare tests, installations, data inventories, dependency records, and known limitations.	Reproducible environment and identified builds.
3 Independent core assessment	4 to 5	Assess the protocol and node together, including Windows operation and Tor integration.	Module A report with evidence and limitations.
4 Independent app assessment	4 to 7	Assess keys, pairing, local data, network paths, and device states.	Module B report for each assessed platform.
5 Dashboard and reporting process	6 to 8	Assess case separation, storage, access, deadlines, and replies; obtain separate legal review.	Module C report and separate process assessment.
6 Whole system assessment	8 to 9	Test complete workflows and separation between customer instances.	System report D and completed claims matrix.
7 Remediation and retesting	10 to 11	Fix findings and retest affected components and interfaces.	Retest evidence for the proposed release.
8 Pilot release approval	12	Sign release artifacts and approve documentation, reports, and the pilot environment.	Approved limited pilot release.
9 Pilot and publication	13 to 16	Evaluate operation and usability, resolve findings, and publish assessed claims.	Evaluated pilot and approved public summary.

App assessment in weeks 4 to 7 assumes parallel capacity. Whole system testing follows the relevant module results. Remediation may begin before weeks 10 to 11.

If a protocol finding changes the architecture, adjust or repeat the affected app, server, and system tests. Replan the schedule accordingly.

Phase 1 assessment preparation

Before external assessment, establish the following records.

1. Components and repositories covering the protocol, node, Windows installer, each available mobile platform, Compliance dashboard, update mechanism, and Tor configuration.
2. Exact assessment baselines including commit hashes, build numbers, installer hashes, dependencies, and tested configurations. A component assessment is not automatically approval of the whole product.
3. Supported operating systems and prerequisites covering permissions, background operation, connectivity, Tor reachability, sleep behaviour, storage, and ports.
4. Data flows for pairing, sending, depositing, fetching, replying, expiry, opening and handling cases, and removing a case from a phone.
5. A data inventory covering the phone, node, dashboard, Windows environment, logs, Tor directories, backups, updates, and diagnostics.
6. Attackers and trust boundaries including an unauthorised user, a malicious contact, a network observer, a server administrator, a stolen data store, a compromised device, and an attacker targeting updates.
7. Precise definitions of anonymity, contact recognition, real identity verification, and TTL deletion.
8. Known gaps and limitations disclosed to the auditor. A narrow scope must not conceal a dependency that is necessary to establish a claim.

Claims and required evidence

Record a result for each claim as met, partially met, not met, or not assessed. Also record the version, configuration, evidence, limitations, and retest status. Product descriptions alone do not establish that a claim is met.

C01 No personal account identifiers are required

Check registration, pairing, APIs, databases, logs, and diagnostics for required names, phone numbers, email addresses, or centrally linkable identifiers. Describe pseudonymous keys and mailbox identifiers separately rather than treating them as if they do not exist.

C02 Each customer receives a separate system instance

Demonstrate separation of state, keys, and configuration. Attempts to use data or access rights from instance A against instance B must fail. Describe access available to the operator and to NexonAI.

C03 Intended anonymous message connections use Tor

Measure the actual network paths on every assessed platform. Test failure cases, DNS requests, direct connections, and unintended fallback behaviour. Describe operating system and update traffic separately.

C04 The node receives neither plaintext messages nor decryption keys

Assess the protocol and key management, including the clients. Examine stored data and relevant server runtime state. Include manipulation attempts and error paths.

C05 Packages are no longer normally accessible after their TTL expires

Define when TTL starts, which clock is authoritative, permitted values, and the maximum acceptable cleanup delay. Test expiry boundaries, restarts, crashes, sleep, and time changes. Assess access prevention separately from physical data cleanup.

C06 Pairing reliably recognises the authorised contact

Assess first contact, key exchange, protection against interception or substitution, reused or expired pairing codes, key changes, and revocation. Mapping a paired contact to a real person requires a verified first contact.

C07 Phone messages persist only within the documented limits

Inventory message content, keys, and the contact book separately. Examine databases, files, notifications, app previews, backups, and crash data. Describe memory cleanup only within demonstrable limits.

C08 The PIN and panic PIN perform their documented functions

Test rate limits, device locking, app restart, and local attack paths. For the panic PIN, state exactly which data is deleted or made cryptographically inaccessible and which operating system limitations remain.

C09 Compliance supports reporting and replies without mandatory identification

Assess the shared entry code, case numbers, case keys, reply path, logs, and possible linkage between different cases. A person may still choose to identify themselves in the report content.

C10 The documented Windows setup works

On fresh supported devices, install the program, press Play, send and receive messages, and restart the system. State network and background-operation prerequisites. Check safe defaults and avoid unnecessary administrator privileges.

Module A protocol node and Windows

Protocol and cryptographic model

- Document and assess key generation, randomness, key purposes, transfer, and storage.
- Assess message authenticity and integrity, replay attacks, confusion between contacts or instances, and unauthorised changes.
- Examine mailbox identifiers, changing labels, and authorisation data for predictability, reuse, and linkability.
- Define behaviour for lost devices, key changes, contact revocation, and repeated pairing.

- Have custom cryptography or protocol extensions reviewed by appropriately qualified specialists.

Node assessment

- Test unauthorised reads, writes, deletion, overwriting, and mailbox enumeration.
- Test packet formats, sizes, time values, and malformed input.
- Test limits on package size, package count, disk use, requests, and cleanup work. If controls introduce central person-level identifiers, reassess C01 and C09.
- Exercise TTL handling during normal operation, concurrent retrieval, restart, crash, sleep, disk exhaustion, and clock changes.
- Examine transaction logs, backups, temporary files, crash dumps, and old database pages. Inaccessibility through the API is not proof of forensic unrecoverability.
- Minimise and document all network and administrative interfaces.

Windows and Tor operation

- Establish supported Windows versions and installation modes. Other versions are not automatically covered by the assessment.
- Assess permissions, file access, local bindings, ports, reboot recovery, and safe failure behaviour.
- Make availability prerequisites visible. A node can supply messages only while its device and service are reachable. Sleep or network interruption must not produce a misleading success indication.
- Assess Tor integration against the actual architecture, including onion service keys and configuration where applicable, and dependency maintenance.
- Sign installers and updates. Plan signature verification, tampered-update handling, rollback behaviour, and signing-key changes.
- Check that updates and removal do not create unnoticed data copies or new telemetry paths.

Module B mobile app

Assess each supported platform separately. An Android assessment does not automatically cover an iOS build.

- Assess key creation and storage, contact confusion, pairing, and revocation.
- Verify intended Tor paths, failure behaviour, network changes, and reconnection.
- Examine messages, contacts, keys, app files, caches, backups, notifications, and app-switcher previews.
- Test the PIN and panic PIN, including unlocked, lost, and compromised-device scenarios. Do not claim protection of all content on a fully compromised operating system.
- Verify message states when the node is unreachable, the recipient is offline, a package has expired, a duplicate arrives, retrieval is interrupted, or the app crashes.
- Review releases, updates, dependencies, and any analytics, push, or crash-reporting services.
- Select applicable OWASP MASVS requirements and MASTG test methods. Document applicability and results rather than assuming every category is covered.

Module C Compliance dashboard and process

- Assess case separation, access, and implemented roles. Do not describe a role model as available unless it exists.

- Assess random case numbers, separate keys, and shared entry codes for hidden individual identification.
- Examine password protection and encryption on the laptop, including offline attack and password loss. Document intentional non-recoverability.
- Check logs, backups, automatic diagnostics, and local files for identity and content leakage.
- Test acknowledgements, replies, status changes, and deadlines. The existing product description specifies seven days for acknowledgement and three months for feedback; assess legal applicability separately.
- Keep package TTL and case records distinct. Removing a package does not automatically remove the reporting office's case record.
- Confirm the current implementation of single-case deletion and export. Both were described as unfinished in the earlier product material. Resolve retention and required deletion before productive Compliance use; assess export requirements separately.
- Keep technical results and legal conclusions separate. A technical audit does not automatically establish complete data protection or whistleblower-law compliance.

Module D complete system and installation

Test the following scenarios using two separate customer instances.

1. Pair two confirmed contacts, send a message, fetch it, and reply.
2. Have an unauthorised client attempt to read, alter, or delete someone else's packages.
3. Keep the recipient offline and reconnect before or after expiry. Verify that displayed states match actual availability.
4. Exercise node restart, Windows sleep, network changes, app crashes, and time changes.
5. Test manipulated or reused pairing data, contact revocation, and key changes.
6. Examine unintended direct network paths and identifying metadata throughout the workflow.
7. Examine the consequences of a stolen or copied node data store, including visible identifiers and patterns.
8. Attempt access or confusion between customer instances A and B.
9. Open a Compliance case without giving a name, exchange replies, acknowledge it, and process it. Assess whether another report from the same phone can be linked to it.
10. Test voluntary identification, removal of a case from the phone, and separately governed retention by the reporting office.
11. Test a modified update, reset configuration, and invalid signature.
12. Install the pilot release on a fresh supported Windows device using the instructions.

The Tor network itself need not be re-audited as part of the product assessment. Product integration and Tor's relevant limitations still belong in the report. An observer able to watch relevant networks may investigate timing correlations, so the assessed anonymity claim must name its threat model.

Auditor selection and assessment brief

Send the same scope to two or three suitable providers. Confirm expertise in mobile security, cryptography and protocols, Windows, and Tor integration. Different specialists may cover different modules.

Ask each proposal to state the following.

- Included components, versions, platforms, and assessment days by module.
- Source review and dynamic testing, with methods and selected criteria.
- Exclusions, dependencies, and the process for newly discovered relevant interfaces.
- Handling of test data, secrets, and vulnerabilities within authorised test environments.
- Immediate notification of critical findings and regular progress reporting.
- Separate detailed reports, a claims matrix, and a public summary.
- Included retesting, deadlines, additional charges, and the effect of code changes on earlier results.
- Permitted public wording and use of the auditor's name or logo.

Set the budget after scope definition and comparable proposals. Separate internal preparation, external modules, legal review, remediation, retesting, pilot operation, and ongoing reassessment. A fixed total would not be reliable without knowing the codebase and platform scope.

Findings remediation and release approval

For every finding, record an ID, affected version and component, reproducible description, prerequisites, impact, severity, owner, remediation state, and retest evidence.

The proposed release criteria are as follows.

1. No open critical or high-severity findings in the approved scope. The owner explicitly accepts and documents any other remaining risk. Risk acceptance is not remediation.
2. Publicly advertised properties are supported for the release version or are restricted or removed from product communications.
3. Fixes are retested on the actual release. Reassess affected interfaces even when the change was made in another module.
4. Supported configurations, network and device prerequisites, logging, backups, and residual limitations are documented.
5. Retention, required deletion, responsibilities, and applicable process requirements are resolved before productive Compliance use.
6. Installation artifacts, update artifacts, and assessment results map unambiguously to the approved version.

A module that was not assessed remains unassessed. A server report does not approve the mobile app or establish absolute anonymity.

Pilot operation in weeks 13 to 16

Use one or two suitable organisations, small participant groups, separate instances, and initially synthetic or non-sensitive content. Do not start with a life-critical communication role.

- Observe customer installation against the instructions and document assistance and prerequisites.

- Measure the actual install-and-start workflow. Do not publish an invented setup-time claim.
- Exercise reboot, sleep, network interruption, Tor reachability, offline reception, and TTL behaviour.
- Test maintenance, signed updates, recovery, and device or key loss using the documented procedures.
- Gather usability feedback without introducing central telemetry or transferring message content to NexonAI unless the anonymity model and assessment scope are reassessed.
- Review results with the customer. Resolve security findings and obtain external retesting where the change warrants it.

Publication and ongoing maintenance

The public summary should identify the auditor, date, versions, assessed components, criteria, main results, retest state, and limitations. Detailed reports may remain confidential provided public statements do not imply more than the supporting summary establishes.

Suggested wording after a supporting result is available:

“unpruuf version X was independently assessed by [auditor] against the properties specified in the report. The scope covers [components and platforms]. The report and documented limitations are available at [link].”

A limited technical assessment does not justify claims such as fully anonymous, unhackable, data protection certified, approved for every operating environment, or whole system audited when components are missing. An audit is not automatically a certification.

Maintain the following processes after release.

- Publish a security contact and a confidential vulnerability-reporting process.
- Maintain dependencies, Tor versions, supported operating systems, and signing keys.
- Record the effect of every release on earlier assessment statements.
- Reassess scope when protocols, key models, Tor paths, storage, telemetry, or access roles change.
- Retest security-relevant changes and agree a recurring independent review cycle. An annual review is a planning baseline alongside change-triggered reassessment.

The first five working days

Day	Action	Output
1	Inventory components and versions, preserve current builds, and assign owners.	Versioned component list and named responsibilities.
2	Document data flows, stored data, and Tor network paths.	Architecture and data inventory.
3	Define claims C01 to C10, limitations, unfinished functions, and supported devices.	Proposed claims matrix and scope.
4	Build a reproducible environment with two instances and test devices; estimate module effort with developers.	Assessor-ready environment and internal estimate.

Day	Action	Output
5	Request comparable proposals, including retesting and report-publication rights.	Proposals suitable for a scope and budget decision.

This roadmap does not itself commission an external assessment.

References

Standards inform the selection of relevant requirements. Listing a standard does not certify the product.

1. OWASP Application Security Verification Standard. Requirements for applicable application, interface, and access controls. https://owasp.org/projects/asvs
2. OWASP Mobile Application Security Verification Standard. Mobile app assessment criteria. https://mas.owasp.org/MASVS/
3. OWASP Mobile Application Security Testing Guide. Mobile security test methods. https://mas.owasp.org/MASTG/
4. Tor Project. Attacks on onion routing, including timing correlation and strong network observers. https://support.torproject.org/about-tor/security/attacks-on-onion-routing/
5. Microsoft. Authenticode publisher identity and software integrity. https://learn.microsoft.com/en-us/windows-hardware/drivers/install/authenticode
6. Microsoft. Time stamping Authenticode signatures. https://learn.microsoft.com/en-us/windows/win32/seccrypto/time-stamping-authenticode-signatures
7. Product baseline. unpruuf in plain words dated 14 October 2026, together with subsequent product clarifications about Tor, separate customer systems, and Windows server software.